
DevSecOps





Discussion Points

- Challenges
- Left Shift Approach
- Best Practices
- Controls and Framework



Challenges

1. Security is always considered as non-functional requirement, whereas the risk of non-existence is higher than the cost of development
2. Security and Compliance are considered as toll-gates, post development, where it should be part of design
3. Often, Security related observations are signed off to save time, whereas it should be inclusive of the actual estimated time
4. The cost of change is higher, if not included during the designing phase
5. Being proactive is important than being reactive to save cost and time

Inclusion of Security is a cultural challenge. It is considered as equivalent to auditing practice, whereas it is truly a design practice and DevSecOps ensures the right ingredients for the same.

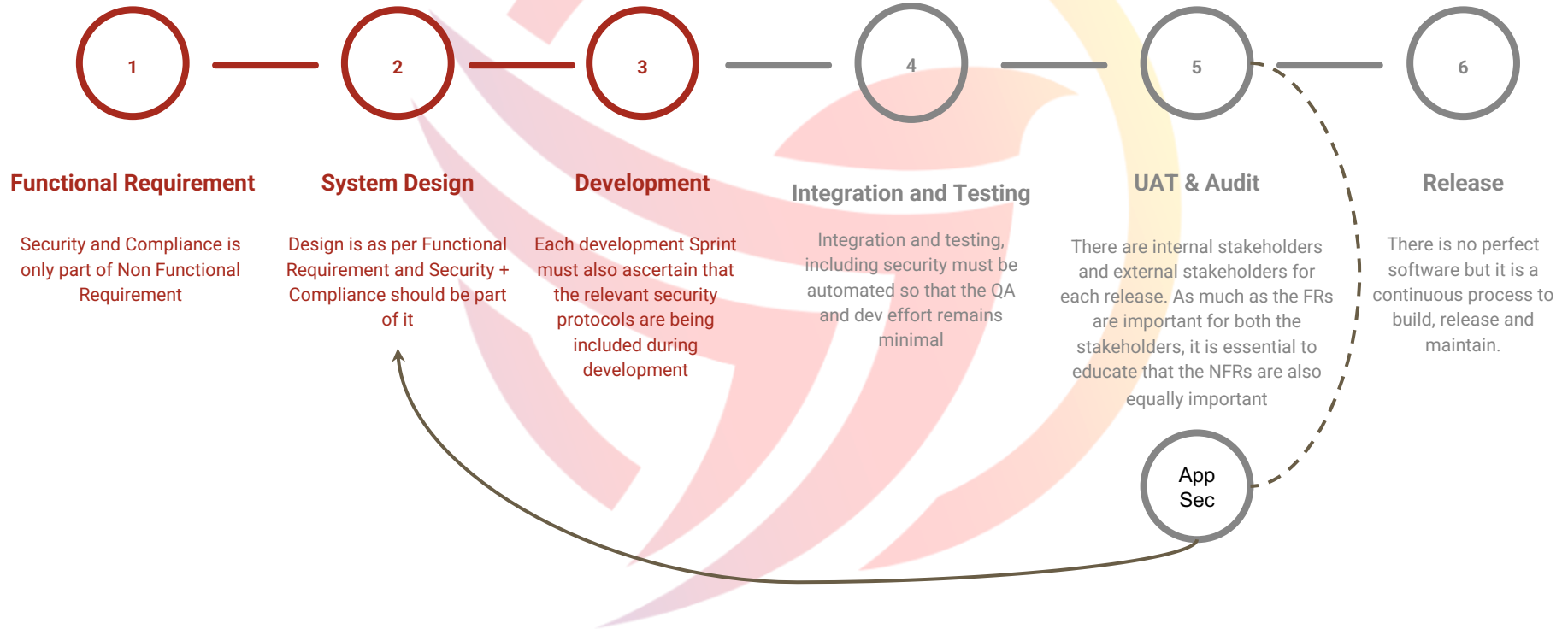


Left-Shift Approach

If we consider a timeline, starting from development at the extreme left to release at the extreme right, security and compliance comes at the end of it (right) as an enabler. Whereas, if we shift the security aspect from testing to design, it will, not only save a lot of cost, but also save time in re-work.



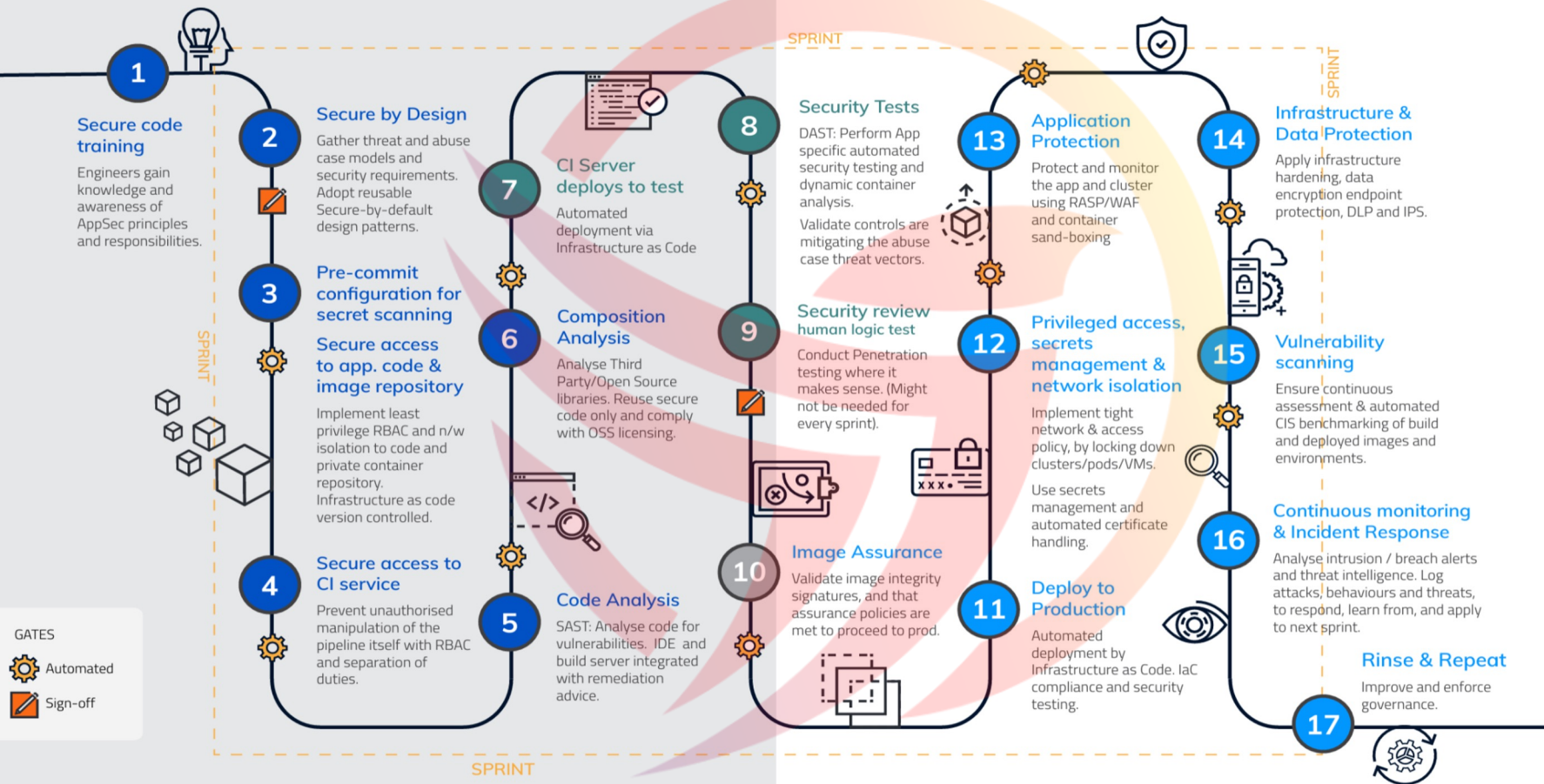
Left Shift Approach





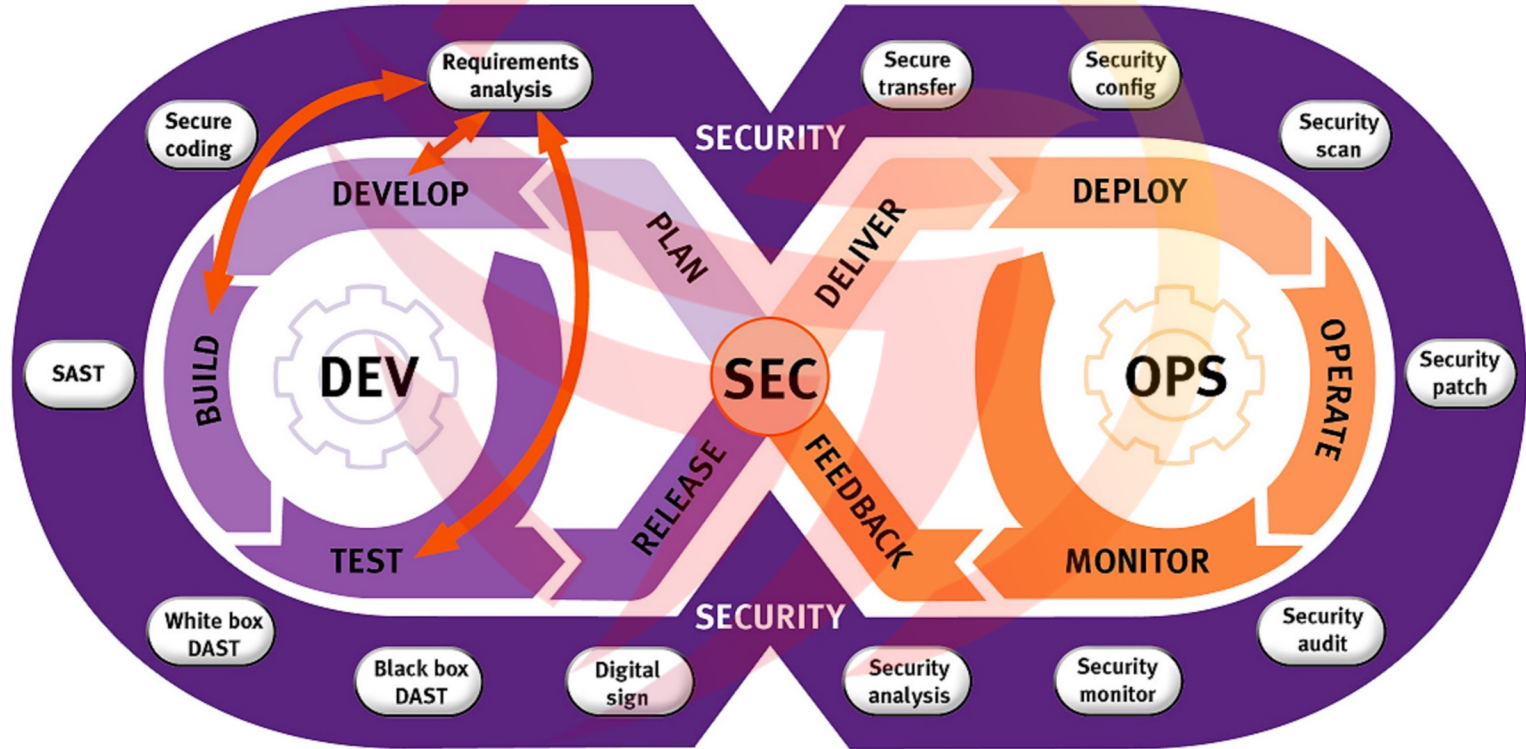
Best Practices

- ❖ Cultural Inclusion
- ❖ Integrate with development sprint
- ❖ Planning during design phase
- ❖ Cost Control by controlling rework effort
- ❖ Remove Toll Gate - Introduce a process for Develop - Sustain - Improve
- ❖ Introduction of Tools and Techniques
- ❖ Security Automation as part of CI/ CD pipeline
- ❖ Independent Testing Team
- ❖ Evidence Based - Solution Approach
- ❖ Centralized Application Security Dashboard
- ❖ Persistence via Containerization of environment



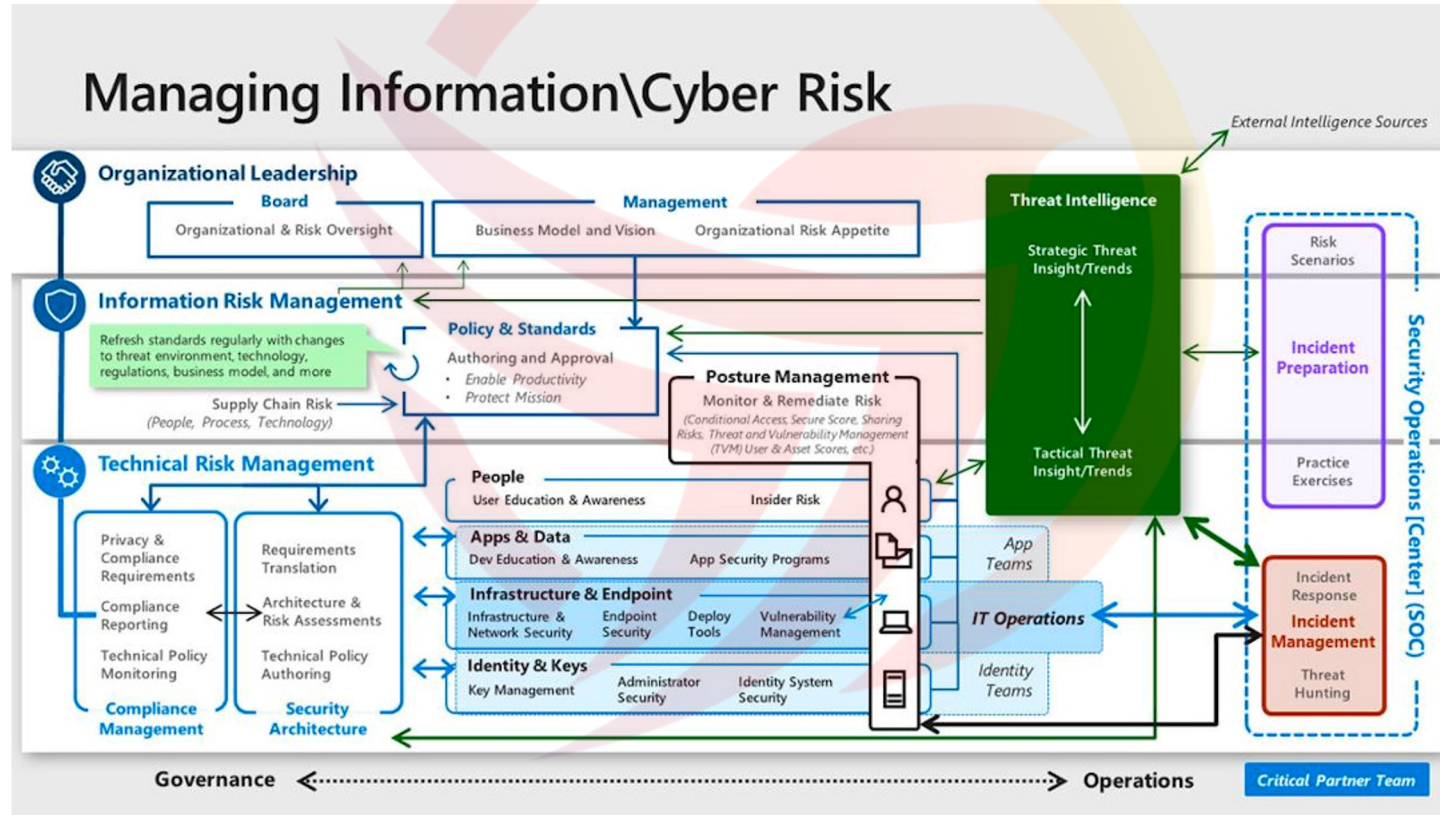


Framework





High Level R-A Matrix





References

- <https://www.microsoft.com/en-us/security/blog/2020/08/06/organize-security-team-evolution-cybersecurity-roles-responsibilities/>
- <https://betterappsec.com/how-to-develop-an-appsec-team-that-will-last-forever-3fc5e96b14fc>
- <https://www.aquasec.com/cloud-native-academy/devsecops/shift-left-devops/>
- <https://learn.microsoft.com/en-us/azure/cloud-adoption-framework/secure/devsecops-controls>

DISCLAIMER: *Image references are publicly available over the internet. Author does not own any image used in this presentation.*

